

Leakage of API key in `api\_base` logging in [berriai/litellm](#)

✓ Valid

Reported on Aug 29th 2024

Description

In `litellm/litellm_core_utils/litellm_logging.py`, the masking code accidentally masks only the first 5 characters.

```
if "key=" in api_base:
    # Find the position of "key=" in the string
    key_index = api_base.find("key=") + 4
    # Mask the last 5 characters after "key="
    masked_api_base = (
        api_base[:key_index] + "*" * 5 + api_base[key_index + 5 :]
    )
```

Proof of Concept

- Set up LiteLLM with Langfuse. https://docs.litellm.ai/docs/observability/langfuse_integration
- Use Gemini / Google AI Studio with LiteLLM.
https://docs.litellm.ai/docs/observability/langfuse_integration
- Look at Langfuse for `api_base`.

e.g. for the fictional GEMINI_API_KEY of `XCExbZ4fuLX-bf5vZq5Q5MvXapVP8JaDnEscQPF`, the `api_base` leaks almost the entire key by logging

`https://generativelanguage.googleapis.com/v1beta/models/gemini-1.5-pro-exp-0827:streamGenerateContent?key=*****Z4fuLX-bf5vZq5Q5MvXapVP8JaDnEscQPF&alt=sse`.

Impact

Exposes a significant amount of a secret key.

Occurrences

`litellm_logging.py` L278-L284



huntr-helper commented a year ago

Admin

This report was determined to possibly be out of scope or have a high likelihood of being marked as informative.

Please review your report and the [Participation Guidelines](#).

These are the specific guidelines this report is in possible violation of:

- Vulnerabilities in code used for tests or example purposes.
- Vulnerabilities related to secrets/private keys being exposed in a github repository



huntr-helper modified the Severity from High (7.7) to High (7.5) a year ago



David Manouchehri commented a year ago

Researcher

This actually exposed the entire private API key, as the first few characters are always the same.



huntr-helper commented a year ago

Admin

This report was determined to not have enough information for the maintainer or the Huntr team to triage.

Please add more details in all sections of the report.

Additionally, at least one PoC (Proof of Concept), needs to be provided. We *strongly* prefer the PoC to be in any of the following formats:

- Sequence of cURL commands
- A script in any programming language
- A Metasploit Module

Please note: while videos demonstrating exploitation are a welcomed addition to the report, they should not be used as a replacement for the PoC.

✉ We have contacted a member of the **berriai/litellm** team and are waiting to hear back a year ago



Ishaan Jaff commented a year ago

Maintainer

this is fixed here:

<https://github.com/BerriAI/litellm/pull/5436/commits/9094071c4782183e84f10630e2450be3db55509a>



A **berriai/litellm** maintainer has acknowledged this report a year ago

✏ The scheduled publication date was automatically extended from 27th Nov 2024 to 4th Dec 2024 due to the maintainers acknowledgement of the report a year ago

⚙️ This report has now been passed to internal triage and should be resolved within 14 days. a year ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✓ Ethan Silvas validated this vulnerability a year ago

Maintainer fixed, marking valid

\$ manouchehri has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

🔑 CVE-2024-9606 assigned to this report. a year ago



✓ Ethan Silvas marked this as fixed in 1.44.12 with commit 909407 a year ago

\$ Ishaan Jaff has been awarded the fix bounty ✓

\$ litellm_logging.py#L278-L284 has been validated ✓



David Manouchehri commented a year ago

Researcher

Which severity field(s) did I miscalculate? Just curious for future reference so I can do better.

✉️ We have notified the **berriai/litellm** maintainers about this report in their weekly follow-up a year ago

⚠️ We have sent a warning to the **berriai/litellm** team to inform them that this report will be published in 48 hours a year ago

📡 This vulnerability has now been published a year ago

🔑 CVE-2024-9606 has now been published 10 months ago

[Sign in](#) to join this conversation

CVE
CVE-2024-9606
Published

Vulnerability Type
CWE-117: Improper Output Neutralization for Logs

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

v1.44.9

Visibility

Public

Status

Fixed

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



David Manouchehri

@manouchehri

UNPROVEN



Fixed by



Ishaan Jaff

@ishaan-jaff

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

